

Active Directory Defensive Project

Role-Based Access Control (GPO)
Course: Computer Network Defense (CND)
Domain: Company.local
Lab: Windows Server 2022 (DC) + Windows 11 + Windows 7 clients (UTM)
Date: September 2026
Name: Piyush Gupta

1. Project Objective

This project implements defense-in-depth access control within an Active Directory (AD) environment using two complementary mechanisms: Role-Based Access Control (RBAC) via Group Policy Objects (GPOs) scoped to Organizational Units (OUs), and a Software Restriction Policy (SRP) to prevent execution of unauthorized software. Together these controls demonstrate least-privilege enforcement and application whitelisting/blacklisting as core blue-team hardening techniques.

2. Lab Environment

Component	Details
Domain Controller	Windows Server 2022
Domain Name	Company.local
Client (GPO testing)	Windows 11
Client (legacy testing)	Windows 7
Virtualization	UTM (macOS host, Apple Silicon)
AD Tools	Active Directory Users and Computers (dsa.msc), Group Policy Management (gpmc.msc)

Part 1 — Role-Based Access Control (RBAC via GPO)

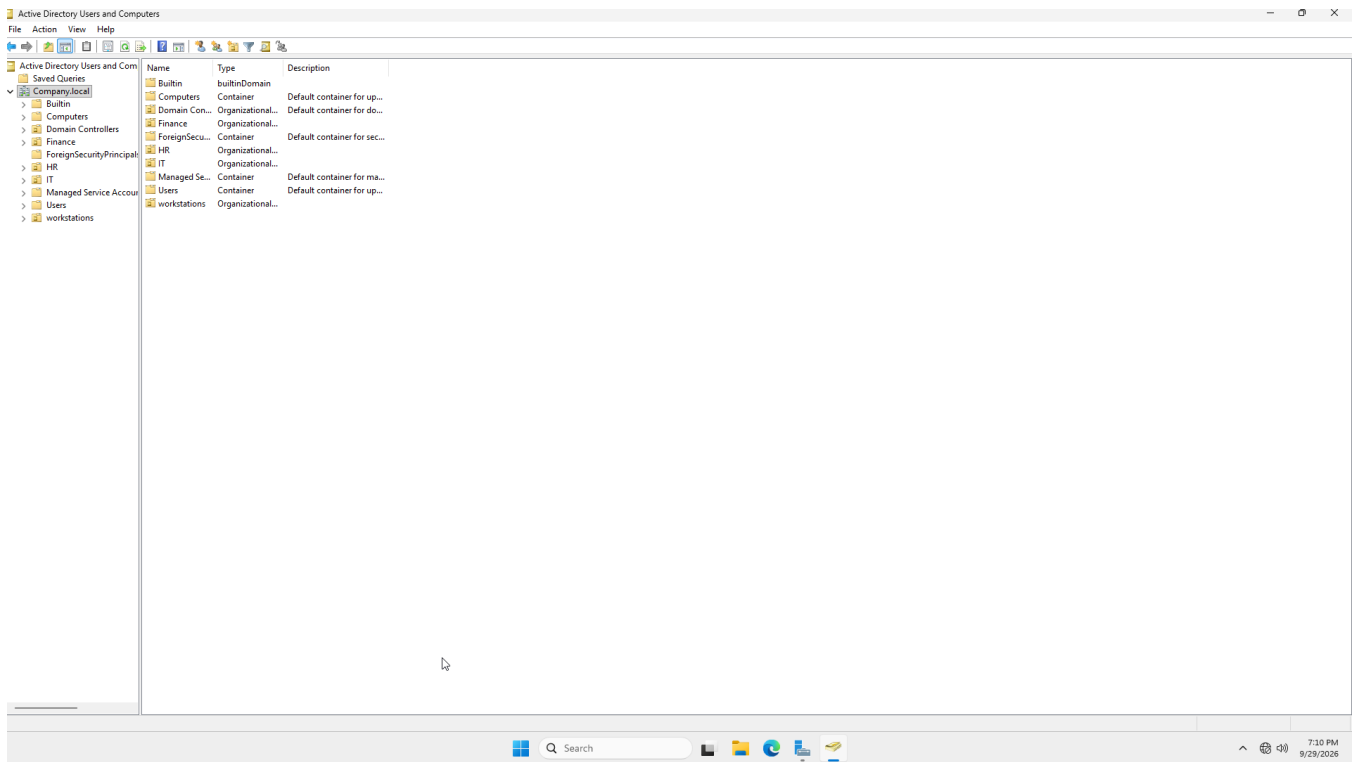
3. Organizational Unit (OU) Structure

Three OUs were created directly under the domain root to logically separate departments and serve as GPO linking targets:

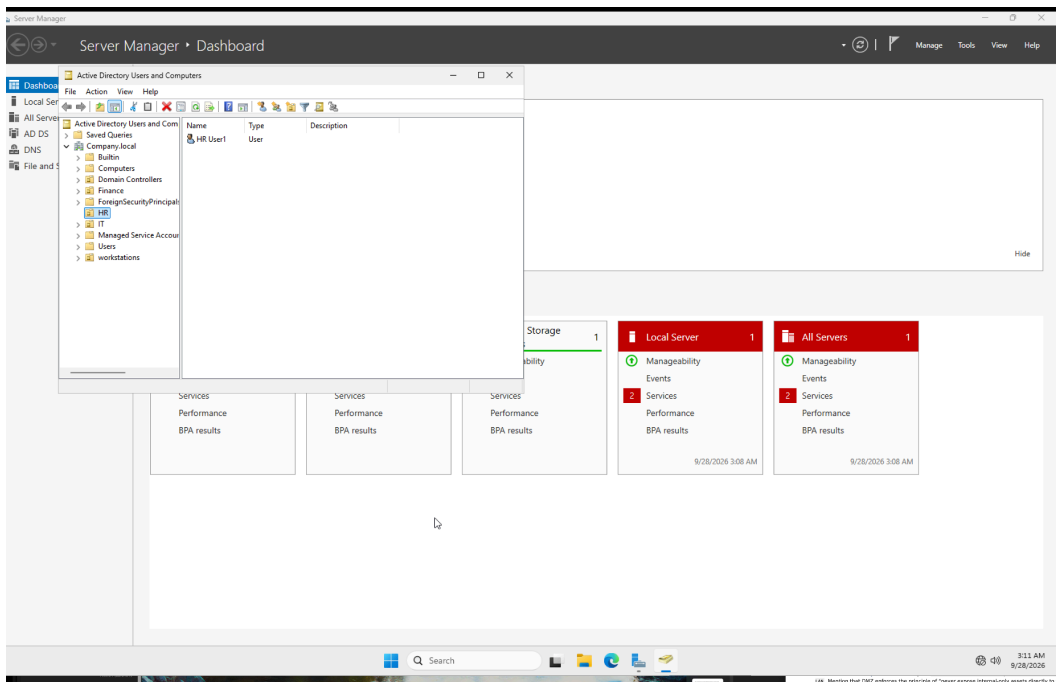
OU Name	Purpose
HR	Human Resources users — restricted tooling, normal desktop use
IT	IT staff — elevated administrative tool access
Finance	Finance users — locked-down USB/Control Panel, strict password policy

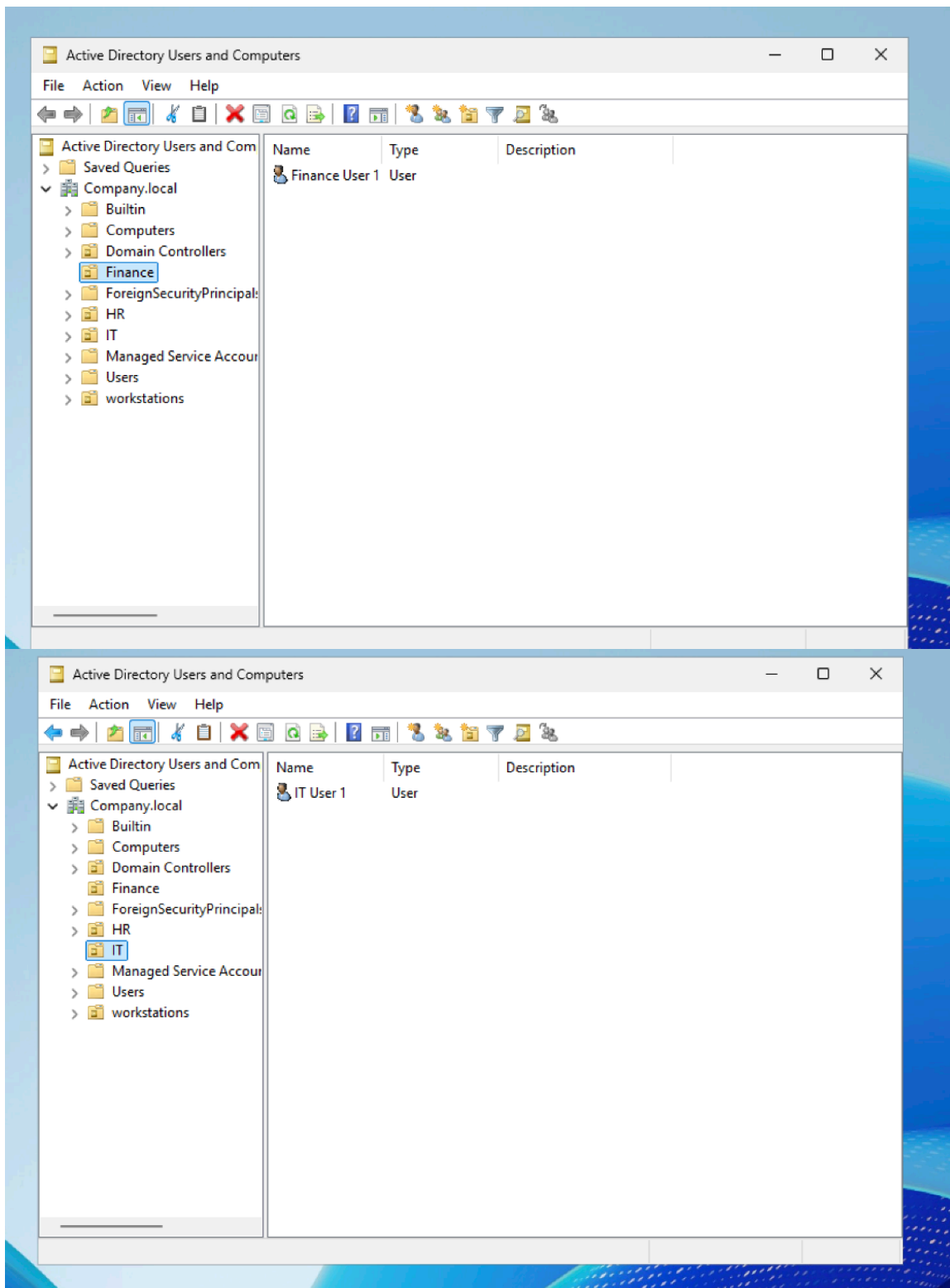
 **SCREENSHOT:** ADUC tree view showing HR, IT, and Finance OUs under Company.local

CND Project — Active Directory Defensive Controls (RBAC)



4. Users Created per OU





OU	User Account
HR	HR User1
IT	IT User 1
Finance	Finance User 1

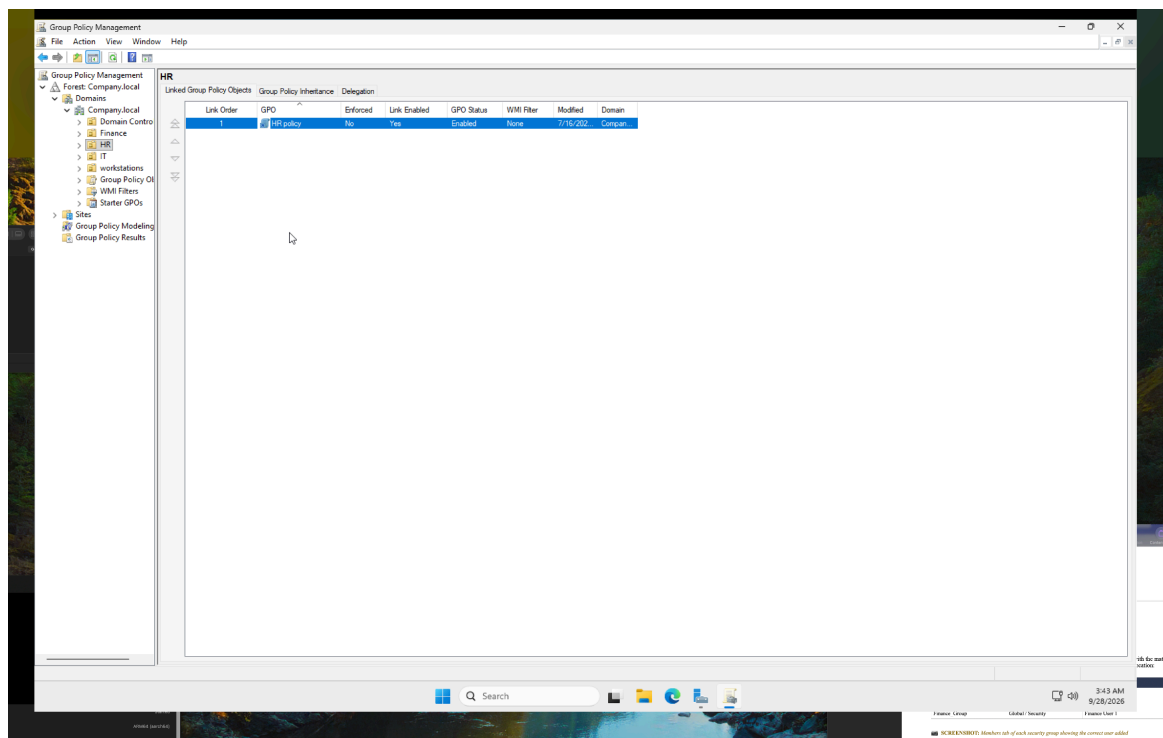
 **SCREENSHOT:** Each OU expanded in ADUC showing its assigned user account

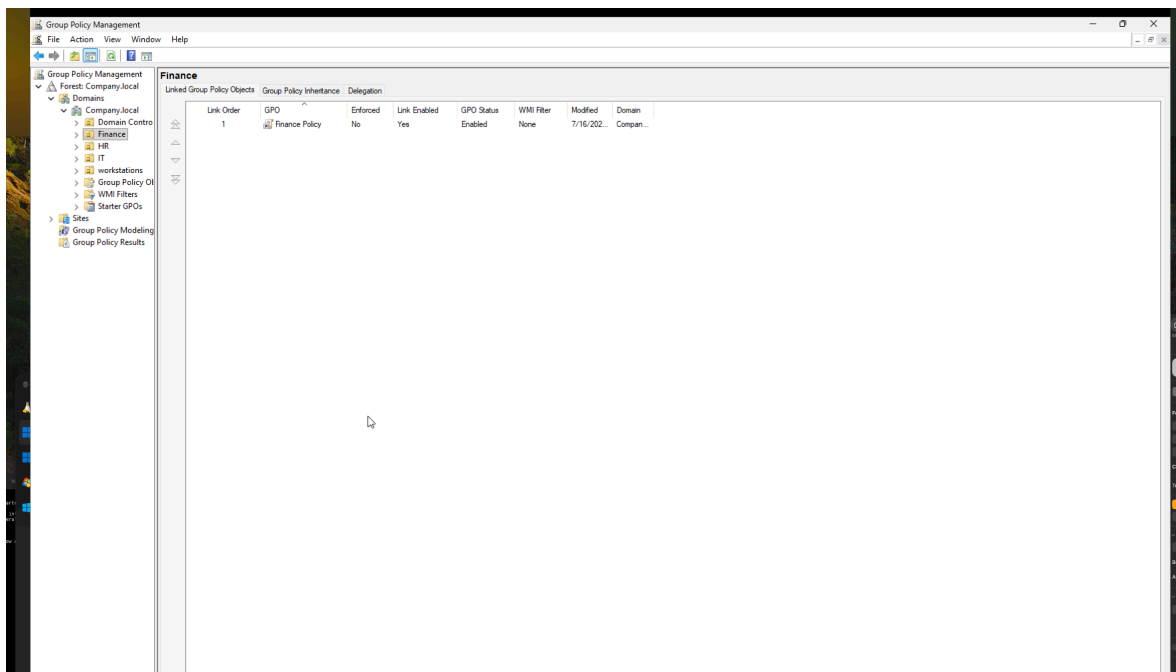
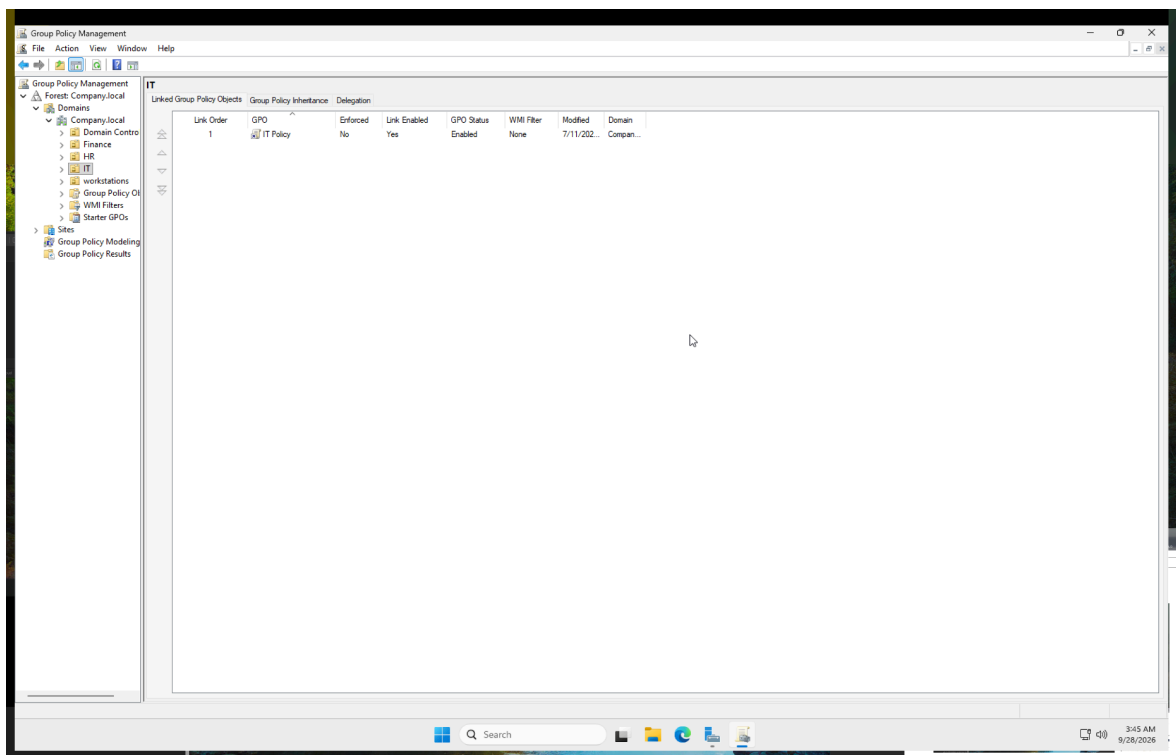
5. Security Groups

One security group (Global scope, Security type) was created per role and populated with the matching user account, to allow permission/GPO targeting by group membership in addition to OU location:

Group Name	Scope / Type	Member(s)
HR_Group	Global / Security	HR User1
IT_Group	Global / Security	IT User 1
Finance_Group	Global / Security	Finance User 1

 **SCREENSHOT:** Members tab of each security group showing the correct user added

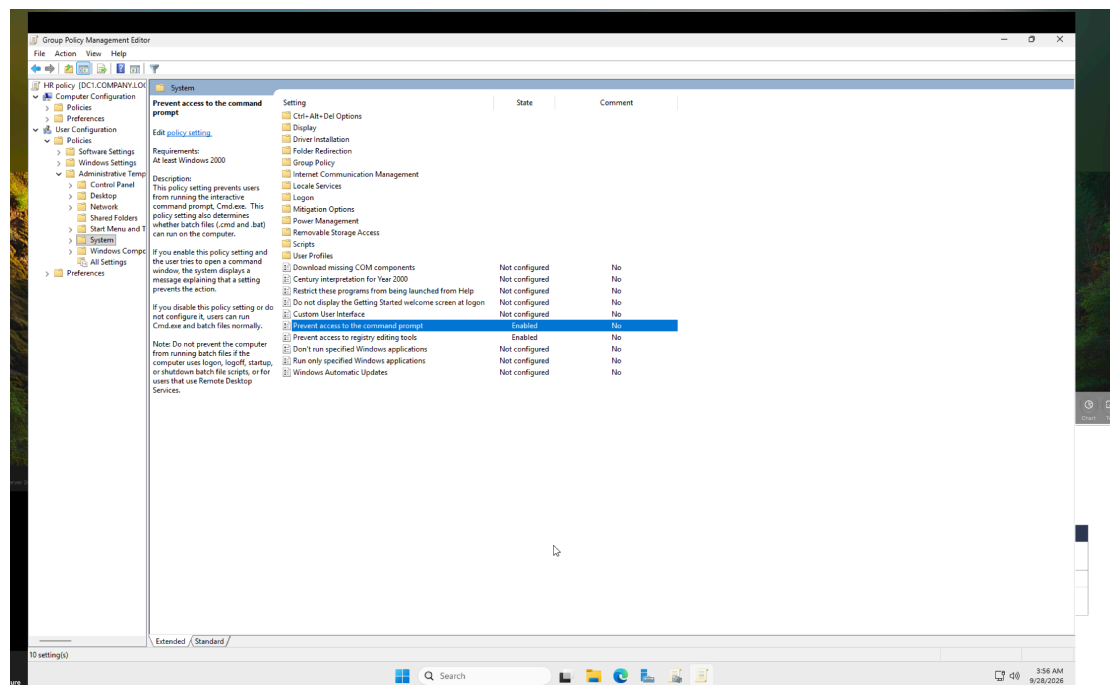




6. Role-Based Group Policy Objects

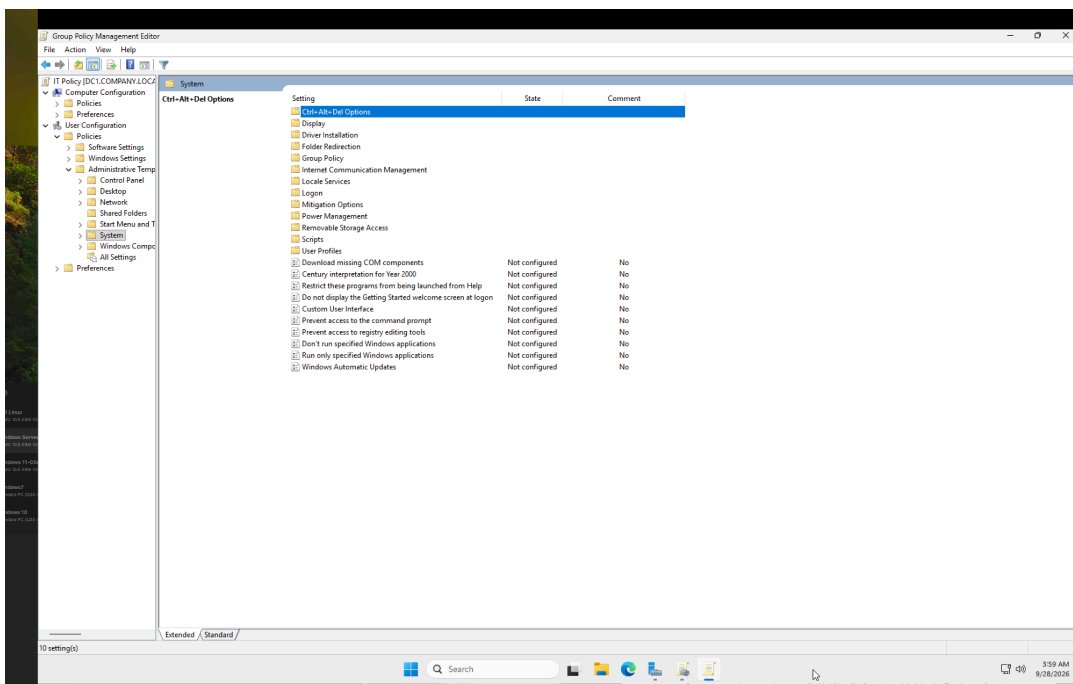
Three GPOs were created in Group Policy Management and linked to their respective OU:

GPO Name	Linked OU	Purpose
HR Policy	HR	Restrict Command Prompt & Registry Editor; allow normal desktop use
IT Policy	IT	Allow Command Prompt, admin tools, advanced settings
Finance Policy	Finance	Restrict USB storage & Control Panel; enforce strict password policy



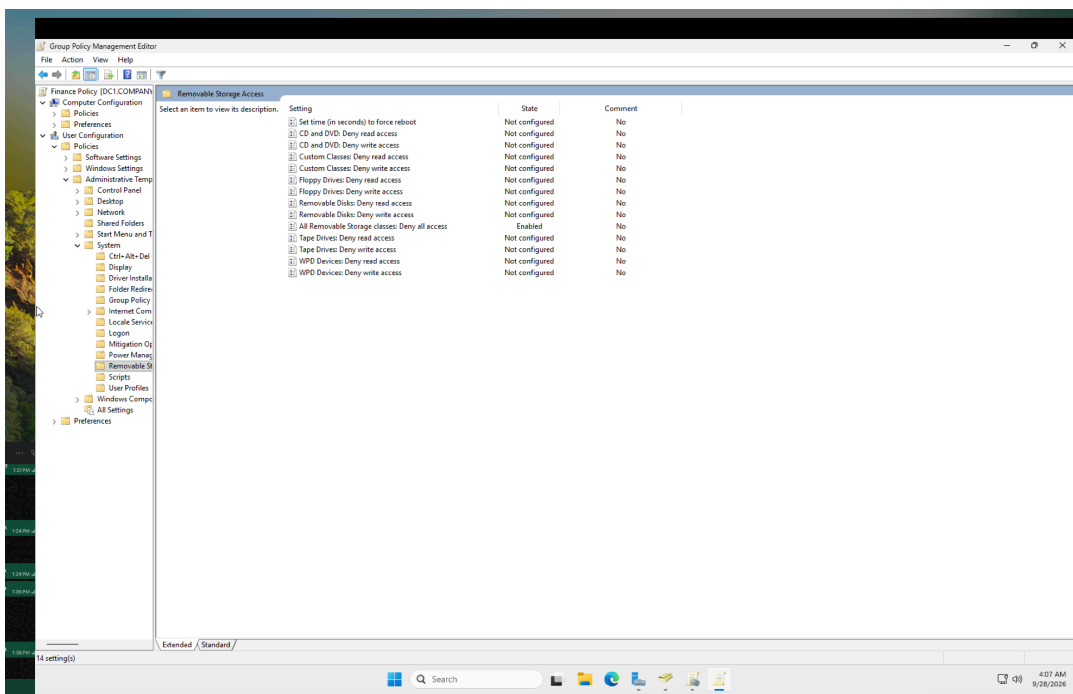
Configured under User Configuration → Policies → Administrative Templates → System / Control Panel:

- Prevent access to the command prompt — Enabled (User Configuration → Administrative Templates → System)
- Prevent access to registry editing tools — Enabled (same path)
- Desktop and standard application access left unrestricted (Not Configured)



Configured to explicitly allow administrative capability rather than restrict it:

- Prevent access to the command prompt — Disabled / Not Configured (access allowed)
- Administrative Tools folder visibility — allowed
- Advanced system settings — Not Configured (default access retained for IT role)



Configured under User Configuration → Administrative Templates → System / Removable Storage Access, and Account Policies → Password Policy:

- All Removable Storage classes: Deny all access — Enabled (blocks USB storage devices)
- Prohibit access to Control Panel and PC settings — Enabled
- Password Policy: minimum length increased (e.g. 12 characters), complexity requirements enabled, shorter maximum password age than domain default

7. Policy Configuration Detail

7.1 HR Policy

Configured under User Configuration → Policies → Administrative Templates → System / Control Panel:

- Prevent access to the command prompt — Enabled (User Configuration → Administrative Templates → System)
- Prevent access to registry editing tools — Enabled (same path)
- Desktop and standard application access left unrestricted (Not Configured)

7.2 IT Policy

Configured to explicitly allow administrative capability rather than restrict it:

- Prevent access to the command prompt — Disabled / Not Configured (access allowed)
- Administrative Tools folder visibility — allowed
- Advanced system settings — Not Configured (default access retained for IT role)

7.3 Finance Policy

Configured under User Configuration → Administrative Templates → System / Removable Storage Access, and Account Policies → Password Policy:

- All Removable Storage classes: Deny all access — Enabled (blocks USB storage devices)
- Prohibit access to Control Panel and PC settings — Enabled
- Password Policy: minimum length increased (e.g. 12 characters), complexity requirements enabled, shorter maximum password age than domain default

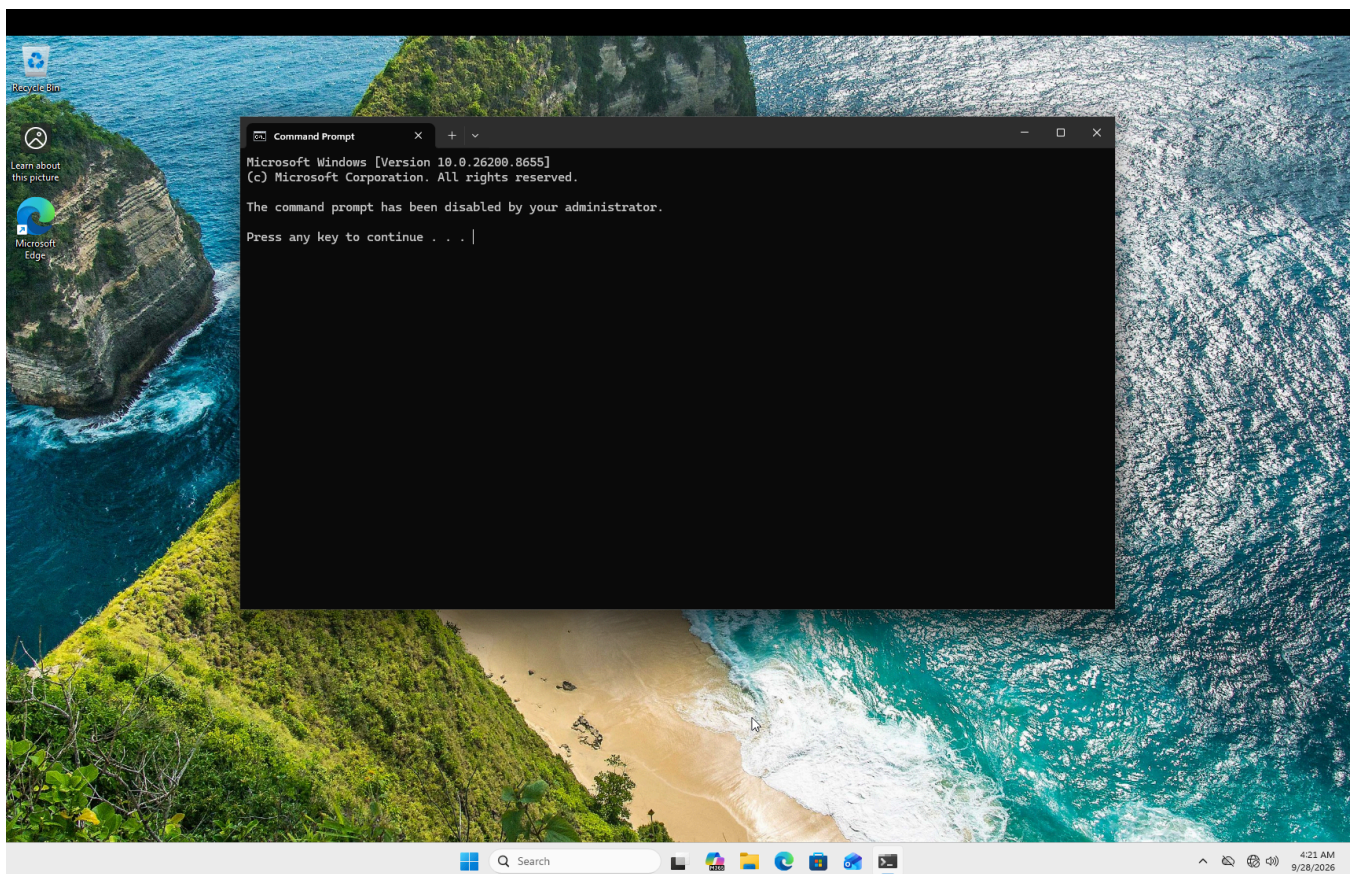
8. Applying and Testing Policies

Policies were pushed to the Windows 11 client and refreshed using:

```
gpupdate /force
```

The client was then used to log in as each of the three test users (hruser1, ituser1, financeuser1) in turn, and the enforced restrictions were observed directly (e.g. Command Prompt blocked for HR, USB drive inaccessible for Finance, admin tools available for IT).

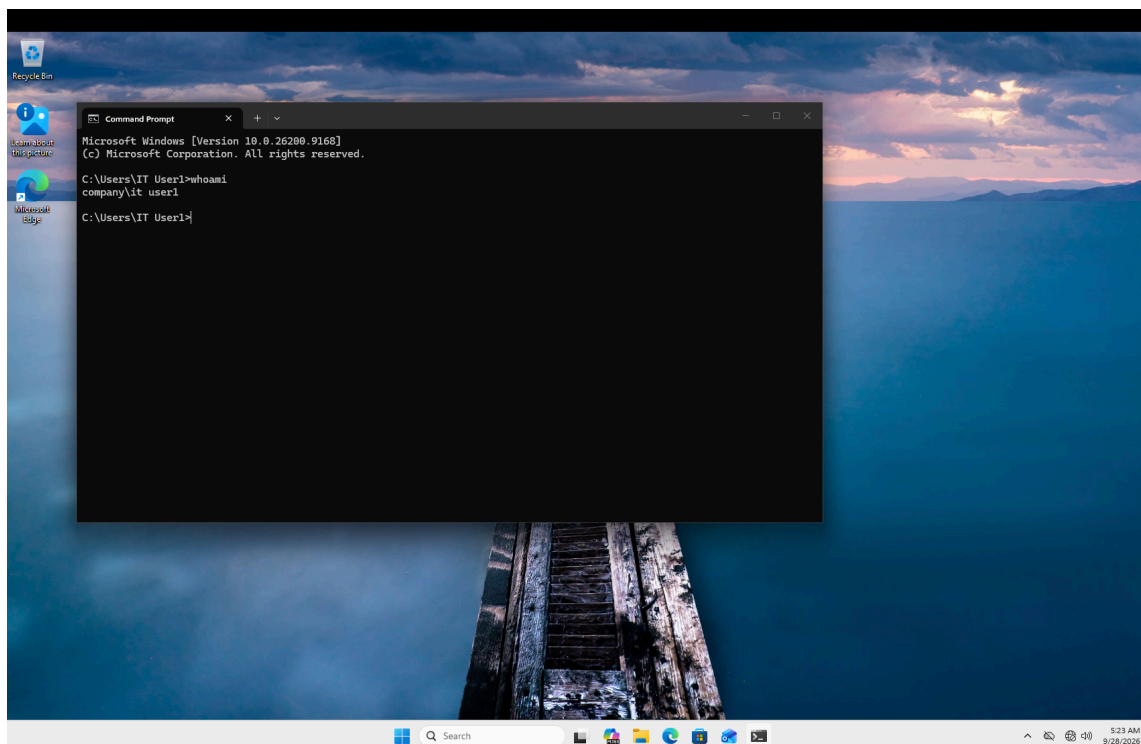
 **SCREENSHOT:** *HR user login — Command Prompt access denied (error message)*



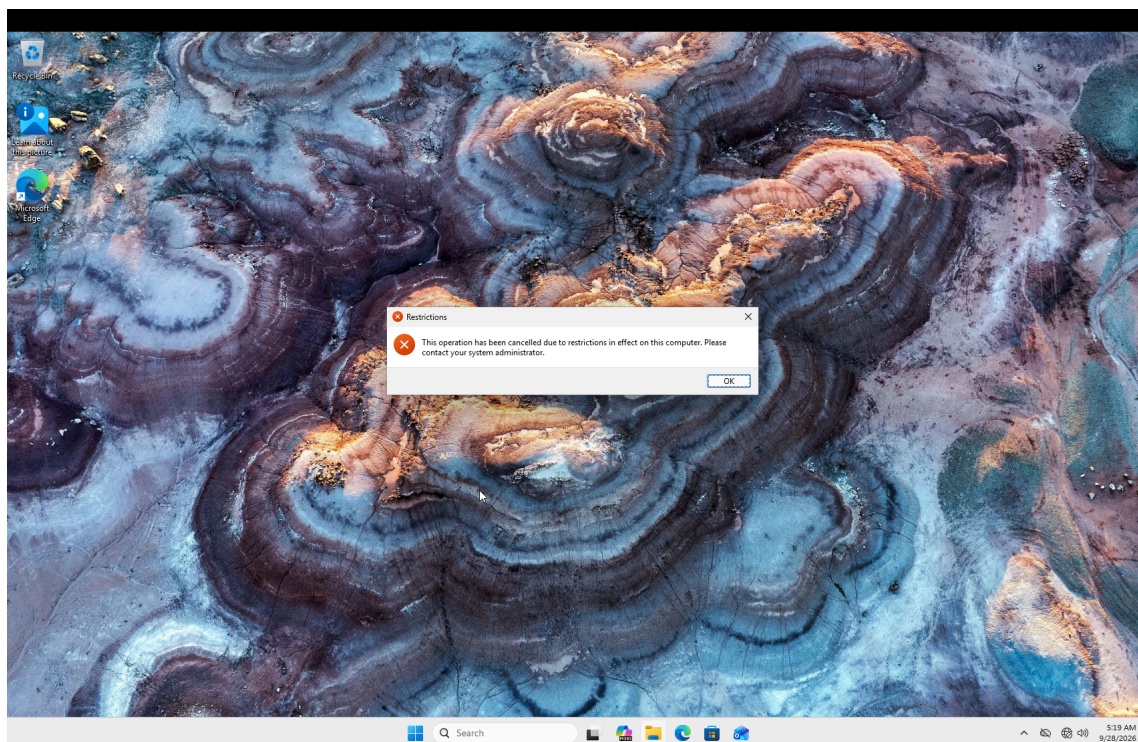
Open windows 11 client —> sign in as other user 'COMPANY\HR user1' and password —> click the search icon near windows button —> type 'cmd'

You will see command prompt getting launched with the message triggered by the rules.

 **SCREENSHOT:** *IT user login — Command Prompt and admin tools accessible*



Open windows 11 client —> sign in as other user 'COMPANY\IT user1' and password —> click the search icon near windows button —> type 'cmd' —> type the command 'whoami'. IT user has the access to the command prompt, but when you try to insert any external device (SD card, pen drive, hard drive) it will throw an error as provided in rules.



SCREENSHOT: Finance user login — Control Panel blocked / USB device inaccessible

Open windows 11 client —> sign in as other user 'COMPANY\Finance user1' and password —> click the search icon near windows button —> type 'Control Panel'.

Finance User does not have the access to the control panel , as we had set rules in the server machine and we can see that it threw an error that means the rules were applied successfully.

9. Verification — Specific Tasks (RBAC)

9.1 Identify: User → Group Mapping

User	Group	OU
HR User1	HR_Group	HR
IT User 1	IT_Group	IT
Finance User 1	Finance_Group	Finance

9.2 Identify: GPO Applied per Role

Role	GPO Applied
HR	HR Policy
IT	IT Policy
Finance	Finance Policy

9.3 Verify: Applied Policies via gpresult

On the client machine, logged in as each test user, the following command lists exactly which GPOs are applied to that session: `gpresult /r`

```
C:\Users\IT User1>gpresult /r

Microsoft (R) Windows (R) Operating System Group Policy Result tool v2.0
© Microsoft Corporation. All rights reserved.

Created on 9/29/2026 at 7:52:31 PM

RSOP data for COMPANY\IT User1 on WIN11-CLIENT1 : Logging Mode
-----

OS Configuration:      Member Workstation
OS Version:             10.0.26200
Site Name:              N/A
Roaming Profile:        N/A
Local Profile:          C:\Users\IT User1
Connected over a slow link?: No

USER SETTINGS
-----

Last time Group Policy was applied: 9/29/2026 at 7:50:02 PM
Group Policy was applied from:    DC1.Company.local
Group Policy slow link threshold: 500 kbps
Domain Name:                     COMPANY
Domain Type:                     WindowsNT 4

Applied Group Policy Objects
-----
IT Policy

The following GPOs were not applied because they were filtered out
-----
Local Group Policy
Filtering: Not Applied (Empty)

The user is a part of the following security groups
-----
Everyone
BUILTIN\Users
NT AUTHORITY\INTERACTIVE
CONSOLE LOGON
NT AUTHORITY\Authenticated Users
This Organization
LOCAL
Authentication authority asserted identity
Medium Mandatory Level
```

9.4 Check: Access Differences Between Roles

Tool / Resource	HR	IT	Finance
Command Prompt	Blocked	Allowed	Not restricted by this GPO
Registry Editor	Blocked	Allowed (default)	Not restricted by this GPO
Control Panel	Allowed (default)	Allowed (default)	Blocked
USB Storage	Allowed (default)	Allowed (default)	Blocked
Administrative Tools	Not applicable	Allowed	Not applicable

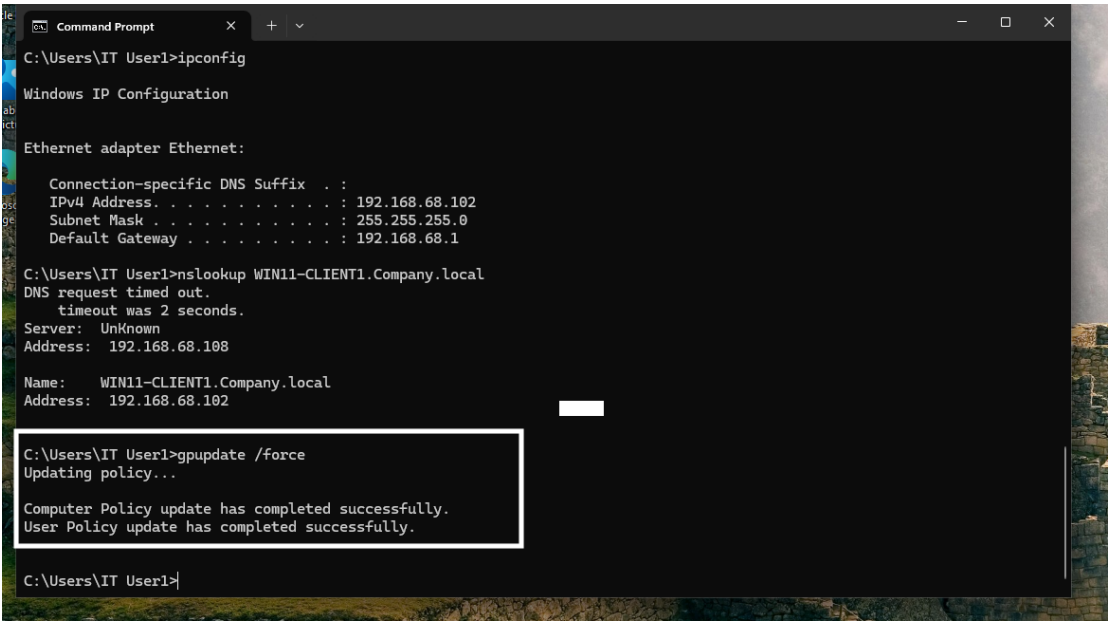
9.5 Identify: Policy Overlap / Conflicts

Since HR Policy, IT Policy, and Finance Policy are each linked to a distinct, non-overlapping OU (HR, IT, Finance respectively) and no user is a member of more than one OU, no direct GPO conflict exists in this design. The only policy layering present is inheritance from parent containers (Section 9.7) — where settings Not Configured at the OU-linked GPO fall back to domain-level defaults, and settings explicitly Enabled/Disabled at the OU level always take precedence over an unconfigured parent setting.

9.6 Test: Moving a User Between OUs

To test whether GPO-based permissions follow OU membership rather than the user account itself, a test user (e.g. HR User1) was moved from the HR OU into the IT OU using ADUC (right-click user → Move...), followed by:

```
gpupdate /force
```



```
C:\Users\IT User1>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 192.168.68.102
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.68.1

C:\Users\IT User1>nslookup WIN11-CLIENT1.Company.local
DNS request timed out.
    timeout was 2 seconds.
Server: UnKnown
Address: 192.168.68.108

Name:   WIN11-CLIENT1.Company.local
Address: 192.168.68.102

C:\Users\IT User1>gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.

C:\Users\IT User1>
```

Result: after the move and a policy refresh, the user immediately lost the HR Policy restrictions (Command Prompt/Registry Editor became accessible) and instead received the IT Policy settings — confirming that GPO enforcement in this design is driven by OU location, not by the user account or group membership alone.

9.7 Verify: Group Membership Impact on Access

Group membership (HR_Group, IT_Group, Finance_Group) in this design was used for organizational/reporting clarity and is available for future permission or software-restriction targeting (e.g. Discretionary Access Control Lists or additional GPO Security Filtering), but the core RBAC restrictions here are enforced via OU-linked GPOs, not via group-based GPO Security Filtering. Moving a user's group membership alone (without changing OU) does not change which GPO applies, since GPOs are linked to OUs, not to groups, by default in this setup.

9.8 Check: Policy Inheritance from Parent OU

By default, GPOs linked to a parent container (e.g. the domain root) apply to all child OUs unless Block Inheritance is set on the child OU or the parent GPO is not Enforced. In this lab, HR Policy, IT Policy, and Finance Policy were linked directly to their respective OUs (not the domain root), so no additional parent-level GPO was inherited beyond the domain's Default Domain Policy (e.g. baseline password/account lockout settings), which still applies to all three OUs unless explicitly overridden.

9.9 Identify: Settings Enforced vs Not Configured

Using gpresult /h (HTML report) or the Group Policy Results Wizard in Group Policy Management, each applied GPO's settings can be reviewed to distinguish between settings that are explicitly Enabled/Disabled (enforced) versus Not Configured (inherited or default behavior applies).

GPO	Explicitly Configured	Not Configured (default applies)
HR Policy	Prevent CMD, Prevent Registry Editor	Control Panel, USB storage, Password policy
IT Policy	Allow CMD / Admin Tools visibility	USB storage, Control Panel

Finance Policy	Block USB storage, Block Control Panel, Password policy	CMD, Registry Editor
----------------	--	----------------------

10. Conclusion

This project demonstrated a layered Active Directory defense strategy combining:

- Role-Based Access Control — OUs, security groups, and GPOs scoped per department (HR, IT, Finance), enforcing differentiated tool access, USB/Control Panel restrictions, and password policy per role
- GPO inheritance and precedence behavior — confirmed via gpresult and the Group Policy Inheritance view, including the effect of moving a user between OUs

Together, these controls enforce the principle of least privilege at both the account/permissions layer (RBAC) and the application-execution layer, reflecting standard defense-in-depth practice for a Windows Active Directory environment.